

LeHart Go-Live Checklist

Everything between the current build and legally taking money from a UK customer. Statuses marked *done* were verified in the repository or against the live deployment.

15 / 112

0 • Blockers

2 / 8

Nothing else matters until these are cleared. Each one either stops money moving or actively exposes you.

- ☒ **Delete the raw card-number field from checkout** DONE

Removed. The payment step now records only which method was chosen — no card number, expiry or CVC input exists anywhere in the DOM, and a note in the code forbids adding them back outside the PSP's hosted fields.
- ☐ **Connect a payment provider** BLOCKER

There is no processor at all today. Nothing charges, authorises or settles.
- ☒ **Seed the production catalogue** DONE

Seeded: 133 products created, `/api/health` now reports `ok` with `productRows: 133`. The storefront and the admin console read the same database at last.
- ☐ **Attach lehart.co.uk to Vercel** BLOCKER

Every canonical tag, Open Graph URL and sitemap entry advertises a domain that does not resolve. Live traffic is on `mobilephonetech-co-uk.vercel.app`.
- ☐ **Rotate the Postgres password shared in chat** BLOCKER

Treat it as public. Rotate even though Postgres is no longer used, if that database still exists anywhere.
- ☐ **Delete and reissue the Firebase service-account key** BLOCKER

The key file was shared in conversation. Revoke it in the Google Cloud console, issue a new one, and update the Vercel environment variable.
- ☐ **Delete BOOTSTRAP_SECRET from Vercel after seeding** TO DO

It gates both the admin-promotion and catalogue-seed routes. With it unset both 404.
- ☐ **Confirm FIREBASE_SERVICE_ACCOUNT has no VITE_ prefix** TO DO

A `VITE_` prefix inlines the value into the browser bundle. That would publish your private key to every visitor.

1 • Payments

0 / 12

Stripe assumed. Refurbished electronics is a high-chargeback category, so expect underwriting questions and possibly a rolling reserve — start the account application early, it is not same-day.

☐ **Stripe account created and business verified** TO DO

UK entity, bank account, company details. Verification can take days.

☐ **Use Stripe's hosted fields or Checkout** TO DO

Card details never touch your server or your DOM, which keeps you in the lightest PCI bracket (SAQ-A). This is the whole reason the raw card field has to go.

☐ **Strong Customer Authentication working** TO DO

3D Secure is handled for you by Payment Intents, but you must test the challenge flow, not just the happy path.

☐ **Webhook endpoint with signature verification** TO DO

Never mark an order paid from a browser redirect — the customer can close the tab. The webhook is the source of truth.

☐ **Idempotency keys on charge creation** TO DO

A retried request must not double-charge.

☐ **Refunds issued through the API against the original charge** TO DO

Wire this to the returns flow so a refund is one action, not a manual dashboard job someone forgets.

☐ **Stripe Radar rules reviewed** TO DO

Baseline: address verification on, extra scrutiny when billing and delivery differ on a first order.

☐ **Apple Pay domain verified, Google Pay configured** TO DO

The express-pay buttons are currently decorative.

☐ **Klarna / Clearpay enabled if wanted** TO DO

Resold through Stripe, so one integration. The product page already advertises instalments — either make it real or remove the claim.

☐ **Statement descriptor set to something recognisable** TO DO

An unrecognised descriptor is a leading cause of chargebacks.

☐ **Currency and pricing confirmed as GBP inclusive of VAT** TO DO

Consumer prices must be shown inclusive.

☐ **Tested with declines, 3DS challenges and expired cards** TO DO

Not only the success card. Test what the customer sees when it fails.

2 • Transactional email

0 / 12

Resend is a good fit — developer-friendly, cheap at this volume. Postmark is the alternative if deliverability of receipts is the thing you care about most. Keep this *separate* from marketing: a receipt that lands in spam becomes a support ticket, and

marketing reputation problems must never take order confirmations down with them.

☐ **Resend (or Postmark) account, domain added** TO DO

☐ **Send from a dedicated subdomain** TO DO

For example `mail.lehart.co.uk`, kept apart from the marketing subdomain. Reputation is tracked per sending domain — this is what stops a bad campaign blocking receipts.

☐ **SPF, DKIM and DMARC published for that subdomain** TO DO

Start DMARC at `p=none` to collect reports, then move to `quarantine` and finally `reject` once you can see nothing legitimate is failing.

☐ **Order confirmation email** TO DO

Legally you must confirm the contract on a durable medium, and it must carry the cancellation-right information.

☐ **Dispatch email with tracking** TO DO

The single biggest reducer of "where is my order" contacts.

☐ **Refund confirmation email** TO DO

☐ **Return instructions and label email** TO DO

☐ **Password reset and email verification** PARTIAL

Firebase Auth sends these by default from its own domain. Rebrand them or route them through your sender.

☐ **Reply-to points at a monitored inbox** TO DO

Customers reply to receipts. If nobody reads that address, you are losing complaints and gaining chargebacks.

☐ **Plain-text alternative on every send** TO DO

HTML-only mail scores worse with filters.

☐ **Bounce and complaint webhooks feed a suppression list** TO DO

Sending repeatedly to a hard bounce is how a sending domain gets throttled.

☐ **Deliverability tested before launch** TO DO

Send to Gmail, Outlook, Yahoo and an iCloud address, and check what actually arrives.

3 • Marketing email

0 / 16

Klaviyo is the ecommerce standard — segmentation and flows are its whole point. Brevo is cheaper, EU-based and already connected to this workspace if budget matters more than flow sophistication.

☐ **Klaviyo (or Brevo) account, separate sending subdomain** TO DO

For example `news.lehart.co.uk`. Separate from the transactional subdomain, for the reason above.

☐ **SPF, DKIM and DMARC for the marketing subdomain** TO DO

☐ **Do not import the existing Firestore newsletter list as-is** **BLOCKER**

New signups now store an evidenced consent record — timestamp, source, policy version, method. Addresses collected before this change still have none of that: re-permission those or drop them. The blocker applies to the old rows, not the new ones.

☐ **Double opt-in on new signups** **TO DO**

Gives you a timestamped, evidenced consent record — the thing the current list lacks.

☐ **One-click unsubscribe headers** **TO DO**

`List-Unsubscribe` and `List-Unsubscribe-Post`. Required by Gmail and Yahoo for bulk senders, not merely good manners.

☐ **Unsubscribe link in every marketing send** **TO DO**

☐ **Preference centre rather than only all-or-nothing** **TO DO**

People who can reduce frequency unsubscribe less often.

☐ **Warm the sending domain up gradually** **TO DO**

Blasting a cold domain with a full list on day one is the classic way to land in spam permanently.

☐ **Suppression synced between marketing and transactional** **TO DO**

Two vendors means two lists. An unsubscribe in one must not be mailable from the other.

☐ **Spam complaint rate monitored below 0.3%** **TO DO**

Gmail's published threshold. Above it, delivery degrades sharply.

☐ **Welcome flow** **TO DO**

☐ **Abandoned basket flow** **TO DO**

Usually the highest-revenue flow in a refurbished shop, where people compare prices for days.

☐ **Browse abandonment flow** **TO DO**

☐ **Post-purchase and review-request flow** **TO DO**

Request reviews only after delivery, and never incentivise without disclosure — see the DMCC item below.

☐ **Back-in-stock notifications** **TO DO**

Especially valuable when stock is single-unit and sells out.

☐ **Trade-in follow-up flow** **TO DO**

Quotes are already captured and currently go nowhere.

These are the ones that catch shops selling second-hand electronics to UK consumers.

☐ **Publish company details on the site** BLOCKER

The footer and legal pages now render the registered name, company number, registered office and VAT number from `src/config/company.ts` — one file to fill in. Until the real values are entered nothing shows, and the invented "LeHart.co.uk Ltd — Registered in England & Wales" line is gone. Still a blocker: the real details must be filled in.

☐ **Terms of sale, distinct from terms of use** PARTIAL

`/terms` exists. Check it actually covers the contract of sale: when the contract forms, pricing errors, stock availability, delivery and title.

☒ **Returns and cancellation policy page** DONE

`/returns` is live: the 14-day cancellation right, refund timescales, diminished-value handling and free prepaid returns, linked from the footer.

☒ **Provide a model cancellation form** DONE

Included on `/returns` as copyable text, as the distance-selling rules require.

☒ **State the 30-day right to reject faulty goods** DONE

On `/returns`, kept explicitly separate from the change-of-mind right, including the six-month burden-of-proof point.

☒ **Warranty terms published** DONE

The 12-month warranty scope — what it covers and what it does not — is published on `/returns`.

☒ **Delivery policy with realistic timescales** DONE

`/delivery` is live and matches the site chrome's next-day promise, with the NI/Highlands caveat and the lost-parcel position. Confirm operationally that the courier arrangement can meet it.

☐ **Total price shown up front** TO DO

Recent consumer law bans drip pricing — mandatory charges belong in the headline price, not revealed at checkout.

☐ **No fake or undisclosed-incentive reviews** PARTIAL

The fabricated 4.8-from-342 aggregate rating found in the product structured data is removed. What remains is a policy point: only publish reviews from verified purchasers once collection starts.

☒ **Condition grading definitions published** DONE

The grading explainer is built and linked from product pages.

☐ **WEEE take-back obligation handled** TO DO

Selling electricals brings a duty to take back old equipment.

☐ **Waste batteries take-back handled** TO DO

Phones contain them, so this applies to you.

☐ **VAT registration position decided** TO DO

And whether you are using the second-hand margin scheme — see the operations section, because it changes what the database must store.

☐ **Product liability and stock insurance** TO DO

High-value small items are the most stolen thing in the parcel network.

☐ **Second-hand dealer registration checked with your council** TO DO

Requirements vary by local authority.

5 • Data protection

1 / 9

☐ **ICO registration and annual fee paid** TO DO

Required for almost every business processing personal data. It is cheap and public — not registering is an easy complaint to make against you.

☐ **Privacy policy matches what you actually do** PARTIAL

Now names the real processors (Firebase, Vercel, the future PSP) and no longer claims an invented ICO registration — that number renders only once the real one is set in `src/config/company.ts`. Retention periods still need writing once decided.

☒ **Cookie policy page** DONE

`/cookies` lists exactly what the site stores — and states plainly that no analytics or ad cookies exist today. The banner links to it.

☐ **Cookie banner actually gates what it claims to** PARTIAL

The banner is built and offers "Reject non-essential", which is the right shape. No analytics or ad scripts are installed yet, so nothing is currently mis-gated — but the moment you add GA4 or a pixel, it must not load before consent.

☐ **Data processing agreements with every processor** TO DO

Google/Firebase, Stripe, Klaviyo, Resend, Vercel. Usually accepted inside each vendor's dashboard.

☐ **Record of processing activities written** TO DO

☐ **Data retention policy defined and enforced** TO DO

Orders have a tax-driven retention period; marketing contacts do not need keeping forever.

☐ **Subject access request process** TO DO

One month to respond. Know in advance how you would export one customer's data.

☐ **Breach notification process** TO DO

72 hours to report a qualifying breach to the ICO. Decide now who makes that call.

6 • Operations

0 / 10

The items that decide whether the shop can actually run, as opposed to whether the website works.

☐ **Per-IMEI stock records** BLOCKER

Products currently carry one grade, one battery health and a `stock` count — a model for identical new boxes. You sell serialised items. Until stock is per-unit you cannot run the VAT margin scheme, cannot answer "which handset did we send them", and cannot price by real condition. Your InventoryManager repo already has an IMEI migration spec — port that model rather than designing it twice.

☐ **Stolen-device checks on trade-in intake** TO DO

CheckMEND is the UK standard. Record the result against the IMEI so you can prove you checked.

☐ **Courier account set up for lithium batteries** TO DO

Phones ship with batteries installed — a declared dangerous-goods category with packaging rules and air restrictions.

☐ **Tracked, insured, signed-for shipping** TO DO

☐ **Returns portal that creates a record** TO DO

The returns modal currently shows three steps and a success message. No record is created and nothing reaches an inbox.

☐ **Inspection and outcome workflow for returns** TO DO

Refurbished returns need a decision — restock, regrade, repair or reject — not just a refund button.

☐ **Prepaid return labels** TO DO

☐ **Margin-scheme stock book feeding your accounts** TO DO

Purchase price and sale price per individual item. Check your accounting software supports the scheme before you commit to it.

☐ **Stock reconciliation routine** TO DO

Weekly at first. Divergence between the database and the shelf is the normal failure mode.

☐ **Support inbox with order context** TO DO

Answering support from a personal email account stops scaling sooner than you would expect.

7 • Security and infrastructure

3 / 9

☒ **Firestore and Storage security rules written and tested** DONE

Rules enforce admin access via custom claims, and the admin E2E suite runs against the Firebase emulator so the rules under test are the ones actually enforced — including an explicit check that a non-admin write is refused.

☒ **Security headers** DONE

Full set now including `Content-Security-Policy`, verified by a dedicated suite that serves the build with the exact production header and fails on any violation event — which is how the Firebase Auth `www.google.com` beacon was caught before deploy.

☐ **Firestore App Check enabled** TO DO

Without it, anyone can call your Firestore directly with your public config. Rules limit what they can do; App Check limits who can ask.

☒ **Rate-limiting on API routes** DONE

Newsletter, trade-in and review submissions are rate-limited per client with 429 + Retry-After, unit-tested. Per-instance limits — a durable shared store is the upgrade path if abuse outruns it.

☐ **Scheduled Firestore backups** TO DO

There is no export configured. A bad admin action or a bad script currently has no undo.

☐ **Error monitoring** TO DO

Vercel shows runtime errors for serverless functions but nothing catches client-side exceptions in a real user's browser.

☐ **Uptime monitoring with alerting** TO DO

☐ **Staging environment separate from production** TO DO

Production currently deploys from a feature branch. Decide deliberately which branch is production.

☐ **Admin accounts use strong unique passwords** TO DO

The credentials discussed in setup were examples and should not survive into production.

8 · SEO, analytics and acquisition

2 / 8

☒ **robots.txt and sitemap.xml published** DONE

Both exist and the admin console is disallowed and marked noindex.

☐ **Canonical domain live and consistent** BLOCKER

Canonicals point at `lehart.co.uk`, which does not resolve. Until the domain is attached you are telling search engines your content lives at a dead address.

☐ **Google Search Console and Bing Webmaster verified** TO DO

☐ **Analytics installed and consent-gated** TO DO

Nothing is installed today. Whatever you choose must not load before consent.

☒ **Product structured data** DONE

Product + Offer JSON-LD with `RefurbishedCondition`, GBP pricing, availability, returns and shipping details on every product page — and the invented 4.8/342 aggregateRating that was hiding in it is removed, with a test that keeps it out.

☐ **Google Merchant Center feed** TO DO

Requires accurate stock and price — so it depends on the catalogue actually coming from the database.

☐ **Trustpilot or equivalent review collection** TO DO

Genuine reviews only. Second-hand buyers check reputation before price.

☐ **Ad pixels consent-gated if used** TO DO

9 · Pre-launch verification

1 / 8

Do these in order, on the real production deployment, the week you go live.

☒ **Full test suite green** DONE

411 unit tests, admin 98, journeys 47, interactions 17, focus 85 pass / 1 warn. Re-run against the release build before launch.

☐ **Place a real order with a real card** TO DO

Your own card, smallest item. Then refund it. This is the only way to know the whole chain works.

☐ **Confirm every transactional email arrives and renders** TO DO

Check on a phone, not only a desktop client.

☐ **Walk the returns path end to end** TO DO

☐ **Test on real iOS and Android hardware** PARTIAL

Emulated mobile viewports are covered by the suites. Real devices catch what emulation does not — keyboard behaviour, Safari quirks, actual tap accuracy.

☐ **Check 404 and error pages** PARTIAL

A wildcard route with noindex is in place. Confirm the server error path too.

☐ **Lighthouse pass on performance and accessibility** TO DO

The bundle currently trips Vite's size warning.

☐ **Verify admin access works for every staff account** TO DO

A custom claim only reaches the browser on a fresh sign-in.

10 · Day one and after

0 / 5

☐ **Watch the payment dashboard for the first orders** TO DO

Manually verify the first handful end to end rather than trusting the automation on day one.

☐ **Monitor email deliverability for the first sends** TO DO

☐ **Check error monitoring daily for the first fortnight** TO DO

☐ **Reconcile stock weekly** TO DO

☐ **Review chargebacks and disputes as they arrive** TO DO

Record the dispatched IMEI so you can evidence exactly what you sent.

READ THIS BEFORE YOU RELY ON IT

The legal, tax and compliance items are enough to know what to ask about — they are not advice. Take the VAT margin scheme, your returns obligations and your published company details to an accountant and a solicitor before launch, and confirm current thresholds and fees at source.

Ticks are stored in this browser only. They are not shared with anyone, do not sync between devices, and will disappear if you clear site data.